Bug Bounty Finding Report

Cyber Security Internship – Phase 3 Submission

Submitted By: Md Yasir
Vulnerability Type: Cross-Site Scripting (XSS)
Target: 195.155.130.147

1. Introduction

Summary:
This report documents a Cross-Site Scripting (XSS) vulnerability identified during bug bounty testing on a live website. The issue was confirmed through a harmless proof-of-concept payload executed in a publicly accessible form field. This report includes the target details, information gathering summary, vulnerability overview, proof of concept, impact, mitigation, and reproduction steps.

2. Target Details

Summary:
The identified issue was found on the following live target during bug bounty testing.

Target URL: https://195.155.130.147/caribou-coffee-franchising-evaluation-form
Bug Name: Cross-Site Scripting (XSS)
Affected Input: Education Status field
Testing Type: Input reflection and client-side payload execution

3. Information Gathering

Summary:
Basic reconnaissance was performed on the target to identify exposed services, observable technology stack, and related infrastructure details.

Information Summary:

IP Address: 195.155.130.147
CNAME: Not Found
Subdomains: N/A
Open Ports: 80, 443
Tech Stack: Microsoft IIS 7.5 / ASP.NET / jQuery
Endpoints:

/caribou-coffee-franchising-evaluation-form (XSS Found) /admin_area (Discovered)
Hosting: teletek.net.tr
SSL Domain: cariboucoffee.com.tr

4. Vulnerability Summary

Summary:

A Cross-Site Scripting (XSS) vulnerability was identified in the Education Status field of the franchising evaluation form. User-controlled input was accepted and executed in the browser without proper sanitization or output encoding. This behavior confirms that attacker-supplied JavaScript can run in the application context.

5. Proof of Concept (PoC)

Summary:

The issue was validated using a harmless JavaScript alert payload to confirm that user-controlled input could execute in the browser context.

Payload Used:

```
"><script>alert("XSS")</script>
```

Vulnerable Parameter / Field:

Education Status

Observed Result:

After submitting the form, a JavaScript alert box appeared in the browser, confirming successful XSS execution.

6. Steps To Reproduce

Summary:

The following steps were used to reproduce the vulnerability on the affected target.

Navigate to: https://195.155.130.147/caribou-coffee-franchising-evaluation-form

Locate the Education Status field in the form

Enter the following payload:

```
"><script>alert("XSS")</script>
```

Submit the form

Observe that the payload executes and a browser alert appears

7. Impact

Summary:
Malicious JavaScript has access to the same objects as the rest of the web page, including data available in the browser context such as cookies and local storage. If sensitive session-related information is exposed through the client side, an attacker may be able to misuse it depending on the application's security controls.

Potential Impacts Include:

Session Hijacking

Cookie Theft

Account Misuse

Data Theft

Phishing Attacks

8. Mitigation

Summary:
The issue can be reduced by improving input handling and output security across the affected form fields.

. Validate and sanitize all user input on the server side

. Apply proper output encoding before reflecting input in the response

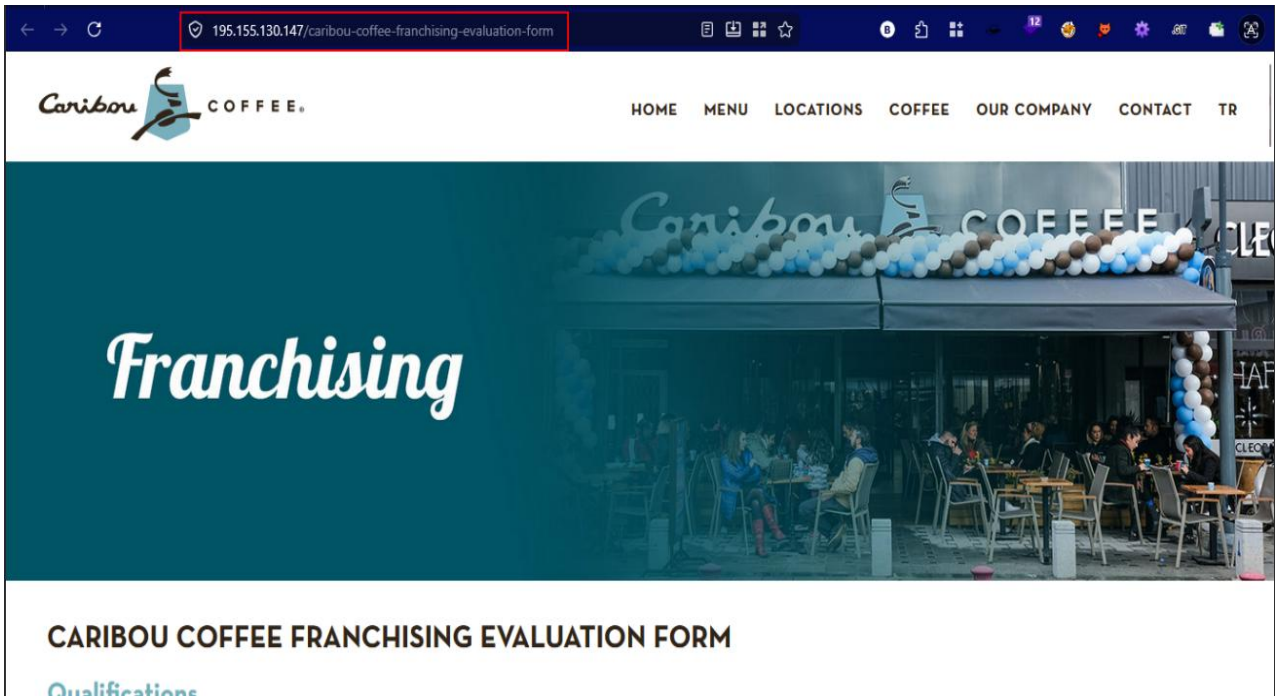
. Avoid inserting untrusted input into browser-executable contexts

. Implement a Content Security Policy (CSP) for additional protection

Screenshots Section

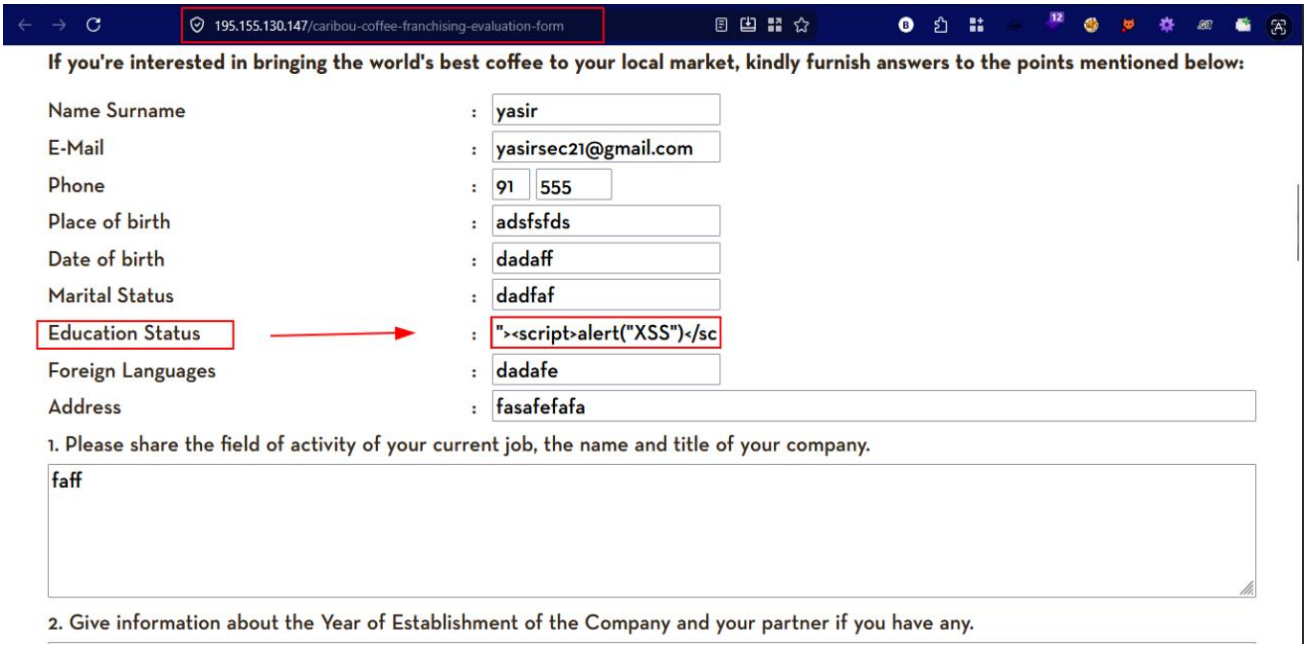
Screenshot 1: Target Page

Caption:
The live target page was accessed successfully for bug bounty testing.



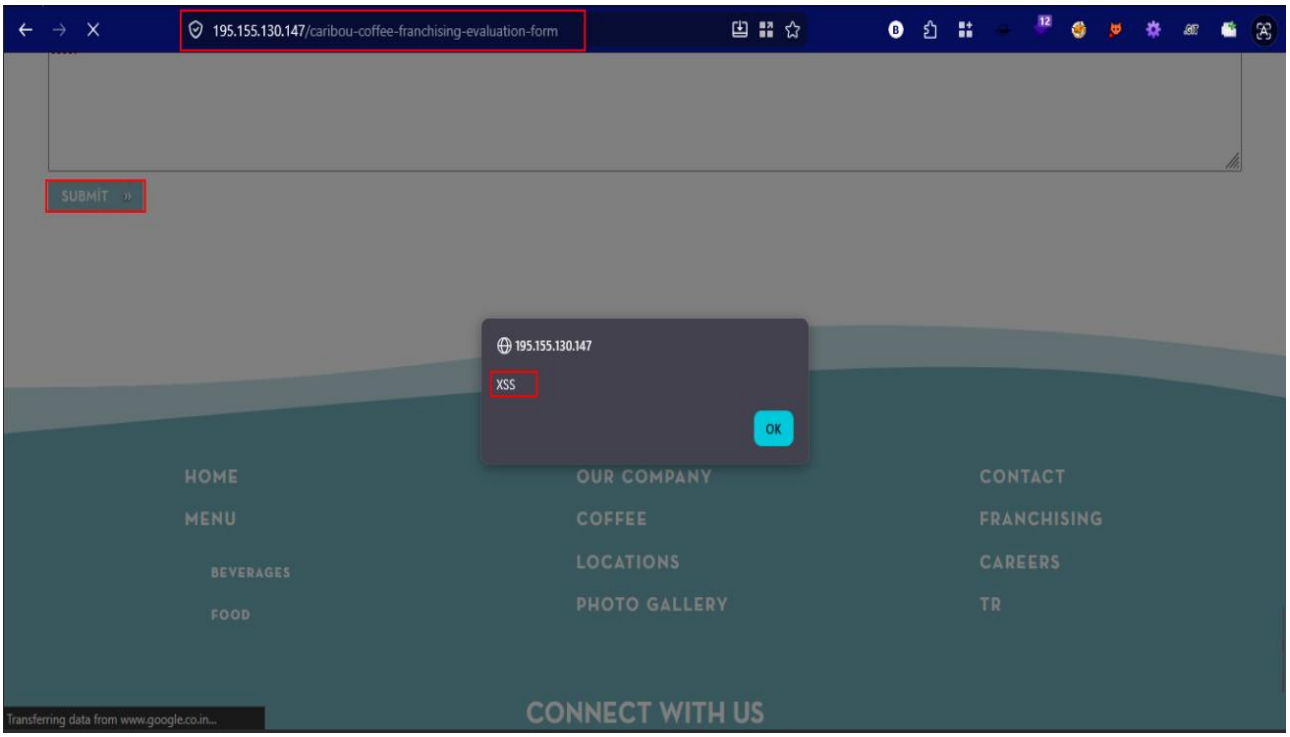
Screenshot 2: Payload Inserted in Education Status Field

Caption:
A harmless XSS test payload was entered into the Education Status field for validation.



Screenshot 3: Alert Popup Confirmation

Caption:
A JavaScript alert appeared after submission, confirming successful XSS execution.



Final Summary

Summary:
The bug bounty activity successfully identified and validated a Cross-Site Scripting (XSS) vulnerability on a live target. The issue demonstrates improper handling of user input in the affected Education Status field. The collected evidence and proof-of-concept confirm the presence of the vulnerability and provide clear documentation for internship submission purposes.

Report Submitted By

Md Yasir
Cyber Security Intern
yasirsec21@gmail.com